Université Paris Cité

SAE CONFORMITÉ RÉGLEMENTAIRE POUR TRAITER DES DONNÉES

RGPD
Règlement Général sur la Protection des Données

CNIL.
COMMISSION NATIONALE INFORMATIQUE & LIBERTÉS

THOMAS AYMARD, MANCEF HENICHE, YUSUF ASLAN & MALIK BESSABIS - BUT SD 2 AVCOD FI

SOMMAIRE

1. INTRODUCTION ET CONTEXTUALISATION 3

2. PRÉSENTATION DES DONNÉES 4

3. VEILLE SUR LES DÉCISIONS ET RECOMMANDATIONS EN MATIÈRE DE CONFORMITÉ DANS LE SECTEUR DE LA GRANDE DISTRIBUTION..... 4-5

4. IDENTIFICATION DES DONNÉES PERSONNELLES DANS LES FICHIERS 5

5. ANALYSE DES RISQUES À L'AIDE DE LA RÉALISATION D'UNE AIPD 6

5) 1. DESCRIPTION DES TRAITEMENTS ET BASES LÉGALES 7

5) 2. DURÉE DE CONSERVATION, TRANSPARENCE DE L'INFORMATION & EXERCICE DES DROITS 8

5) 3. RISQUES POUR LES PERSONNES CONCERNÉES 8

5) 4. MESURES DE PROTECTION TECHNIQUES ET ORGANISATIONNELLES 9

6. REPRÉSENTATION DE L'AIPD SOUS LA FORME D'UN SCHÉMA VISUEL 10

7. APPRÉCIATION DU NIVEAU DE RISQUE ET SOLUTIONS 11

8. CONCLUSION 11-12

1. INTRODUCTION ET CONTEXTUALISATION

SuperPlus, entreprise de grande distribution, s'appuie de plus en plus sur les données pour améliorer la gestion de son activité et mieux comprendre le comportement de ses clients. Les informations collectées concernent l'identité des clients, leurs coordonnées, leurs habitudes d'achat ainsi que leur exposition aux campagnes marketing, représentant un volume important de données personnelles et potentiellement sensibles.

Cette situation met SuperPlus face à un double enjeu. D'une part, l'entreprise souhaite exploiter au mieux ces données afin d'optimiser ses campagnes, fidéliser sa clientèle et améliorer son chiffre d'affaires. Mais d'autre part, elle doit obligatoirement respecter le Règlement général sur la protection des données (RGPD), qui encadre de manière stricte la collecte, le traitement et la conversation des données personnelles des clients. La direction s'inquiète donc des risques de non-conformité, notamment en matière de prospection commerciale, de durée de conservation ou de sécurité des données.

Pour répondre à ces préoccupations, ce travail poursuit plusieurs objectifs. Il s'agit tout d'abord de réaliser une veille ciblée sur les décisions, sanctions et recommandations récentes en matière de conformité RGPD dans le secteur de la grande distribution, afin de rendre SuperPlus réglementé et opérationnel. Nous devons ensuite identifier précisément les données personnelles concernées et à quels types de traitements elles sont soumises.

Sur cette base, nous menons une Analyse d'impact relative à la protection des données (AIPD), telle que prévue par le RGPD pour les traitements susceptibles d'engendrer un risque élevé pour les droits et libertés des personnes concernées. Cette AIPD comprend la description des traitements, la base légale prévue, la durée de conservation, les modalités d'information des clients et d'exercice de leurs droits, l'identification des risques, ainsi que les mesures techniques et organisationnelles envisagées pour les réduire. Enfin, nous proposons une appréciation globale du niveau de risque et des solutions concrètes pour permettre à SuperPlus d'être dans un niveau de conformité satisfaisant.

2. PRÉSENTATIONS DES DONNÉES.

Les données mises à disposition dans le cadre de ce projet proviennent de trois fichiers fournis par SuperPlus : un fichier clients, un fichier d'achats et un fichier décrivant les campagnes marketing. Le fichier clients regroupe les informations relatives à environ 200 personnes, dont des données d'identité (par exemple l'âge, le sexe, nom, prénom), de contact (adresse email, ville) et de relation commerciale (carte de fidélité).
Le fichier achats lui décrit 1000 transactions réalisées en 2023, en précisant notamment la date de l'achat, la catégorie de produit concernée, le montant dépensé et la campagne associée à cet achat. Enfin, le fichier campagne lui est composé de cinq campagnes marketing, avec des informations tels que le type de canal utilisé (par e-mailing, SMS, publicité dans des applications mobiles) et le budget associé. L'ensemble de ces fichiers permet ainsi de relier des clients identifiés, leurs comportements d'achat et les actions de communication dont ils font l'objet, ce qui en fait un jeu de données riche pour l'analyse, mais également sensible via les données personnelles qui y sont présentes.
Pour ce qui est du RGPD, ces fichiers contiennent plusieurs catégories de données personnelles clairement identifiables : données d'identification indirecte (âge, sexe, ville), cordonnées (adresse e-mail), informations liées au suivi de la relation commerciale (carte de fidélité, historique d'achats, exposition aux campagnes). Ces données peuvent être considérées sensible en raison du profilage qui peut être effectué sur les clients. Cette structuration des données appelle donc à un examen précis des traitements réalisés, de leurs finalités et des mesures de protection associées.

3. VEILLE SUR LES DÉCISIONS ET RECOMMANDATIONS EN MATIÈRE DE CONFORMITÉ DANS LE SECTEUR DE LA GRANDE DISTRIBUTION

La veille juridique et réglementaire réalisée pour ce projet met en exergue que le secteur du commerce de détail et de la grande distribution est une cible prioritaire pour la CNIL, compte tenu des volumes massifs de données traitées. Les analyses des décisions récentes montrent que les sanctions visent principalement deux écueils : le manquement à l'obligation de recueillir un consentement libre et éclairé pour la prospection commerciale, et la conservation illimitée des données clients sans tri sélectif. Dans ce contexte, la conformité ne s'arrête pas à la sécurité informatique ; elle impose une gestion éthique du marketing.

La CNIL recommande spécifiquement de limiter la durée de conservation des données issues des cartes de fidélité et d'assurer une traçabilité parfaite des "opt-ins" (consentements). Pour SuperPlus, cela signifie que toute stratégie de profilage ou de campagne ciblée doit être documentée et justifiée pour éviter des amendes administratives lourdes et une perte de confiance des consommateurs.

4. IDENTIFICATION DES DONNÉES PERSONNELLES DANS LES FICHIERS

L'examen approfondi des trois fichiers de données fournis par SuperPlus révèle un écosystème d'informations interconnectées riche mais sensible. Le fichier clients.csv, qui recense environ 200 personnes, contient des données d'identification directe (nom, prénom) et de contact (adresse email, adresse postale) rendant les individus immédiatement identifiables. Il inclut également des données socio-démographiques d'identification indirecte comme l'âge, le sexe et la ville, propices au segmentage marketing. Ce fichier maître est relié via la clé de la "carte de fidélité" au fichier achats.csv, qui détaille 1000 transactions réalisées en 2023. Ce croisement transforme des données techniques (montant, date, catégorie de produit) en données comportementales, révélant les habitudes de vie intimes des clients. Enfin, le fichier campagnes.csv ajoute une couche d'information sur la réactivité aux sollicitations (canal SMS ou email, budget), permettant de déduire la sensibilité des clients à la publicité. L'agrégation de ces sources constitue un traitement de données personnelles complet nécessitant une vigilance maximale.

5. ANALYSE DES RISQUES À L'AIDE DE LA RÉALISATION D'UNE AIPD

En ce qui concerne ces traitements, l'analyse d'impact relative à la protection des données (AIPD) vise à identifier les risques susceptibles d'affecter les droits et libertés des clients, ainsi qu'à évaluer le niveau de gravité et de probabilité de ces risques. Les principaux risques identifiés portent sur la confidentialité des données (accès non autorisé aux fichiers contenant les coordonnées et l'historique d'achats), la perte ou la corruption des données (incident de sécurité entraînant une indisponibilité des informations clients) et l'atteinte à la vie privée via un profilage excessif.

Ces risques sont nombreux par le fait que les données peuvent être croisées entre elles, ce qui permet de reconstruire des habitudes de consommation détaillées, des préférences de produits ou des comportements d'achat. En l'absence de mesures de minimisation ou de limitation d'accès, il existe un risque de détournement de finalité (utilisation des données à d'autres fins que celles initialement prévues), ainsi qu'un risque de non-respect des droits des personnes (difficulté à exercer le droit d'accès, de rectification, d'opposition ou d'effacement). L'AIPD doit donc décrire de manière précise chaque traitement, les flux de données, les acteurs impliqués et les mesures existantes, afin de mettre en évidence les points sensibles.

Dans le cadre du projet, nous avons formalisé l'AIPD sous forme d'arbre de décision, on a distingué les différents traitements (gestion relation-client, analyse des achats et prospection / marketing), nous y avons associés des finalités et base légale, puis les risques associés. Puis nous avons proposé des mesures de sécurités afin d'être correct vis-à-vis du RGPD.

5) 1. DESCRIPTION DES TRAITEMENTS ET BASES LÉGALES

Les données fournies reflètent plusieurs types de traitements mis en œuvre par SuperPlus. Tout d'abord l'entreprise réalise un traitement de gestion de la relation client, qui comprend la création et la mise à jour des fiches clients, la gestion des cartes de fidélité et la centralisation des coordonnées de contact. Ce traitement a pour finalité principale la gestion du compte client, la fourniture du service et le suivi des avantages de fidélité. Sa base légale repose en général sur l'exécution du contrat ou de mesures précontractuelles lorsque le client adhère au programme de fidélité ou effectue un achat.

Ensuite, les données d'achats sont exploitées pour analyser le comportement de consommation, suivre le chiffre d'affaires par catégorie de produits et évaluer l'efficacité des campagnes marketing. Ce traitement d'analyse et de reporting, qui peut aller jusqu'au profilage marketing, poursuit une finalité d'amélioration de l'offre et de pilotage de la stratégie commerciale. Selon les cas, la base légale peut être l'intérêt légitime de SuperPlus (optimisation de son activité, lutte contre la fraude, amélioration des services), à condition de réaliser un test de mise en balance et d'offrir des garanties suffisantes, ou bien le consentement explicite du client lorsque des analyses avancées ou des ciblage personnalisé sont mises en œuvre.
Enfin, les fichiers laissent apparaître des traitements de prospection commerciale, consistant par exemple à adresser des campagnes ciblées (par email ou autre canal) sur la base des informations contenues dans les fichiers clients et achats. La finalité est ici la promotion de produits ou services, ou l'animation du programme de fidélité. En matière de prospection électronique à destination des particuliers, la base légale est généralement le consentement, sauf exceptions limitées, avec la possibilité de se désinscrire facilement à tout moment. Le respect des règles de la prospection constitue un point de vigilance majeur, d'autant que la CNIL sanctionne régulièrement des entreprises pour des campagnes menées sans base légale suffisante ou sans respect du droit d'opposition.

5) 2. DURÉE DE CONSERVATION, TRANSPARENCE DE L'INFORMATION & EXERCICE DES DROITS

La conformité de SuperPlus repose sur la maîtrise du cycle de vie de la donnée et la transparence envers les usagers. Concernant la durée de conservation, nous recommandons d'appliquer la norme simplifiée de la CNIL : les données de prospection doivent être supprimées 3 ans après le dernier contact émanant du client (clic ou achat), tandis que les données de facturation peuvent être archivées plus longtemps pour répondre aux obligations comptables, mais en accès restreint. En matière de transparence, il est impératif d'informer les personnes dès la collecte via des mentions claires précisant les finalités et la base légale. Pour garantir l'exercice des droits, SuperPlus doit mettre en place des procédures simples et automatisées : un lien de désinscription fonctionnel doit figurer dans chaque courriel ou SMS promotionnel, et un formulaire de contact dédié doit permettre aux clients de demander l'accès, la rectification ou l'effacement de leurs informations personnelles dans des délais brefs.

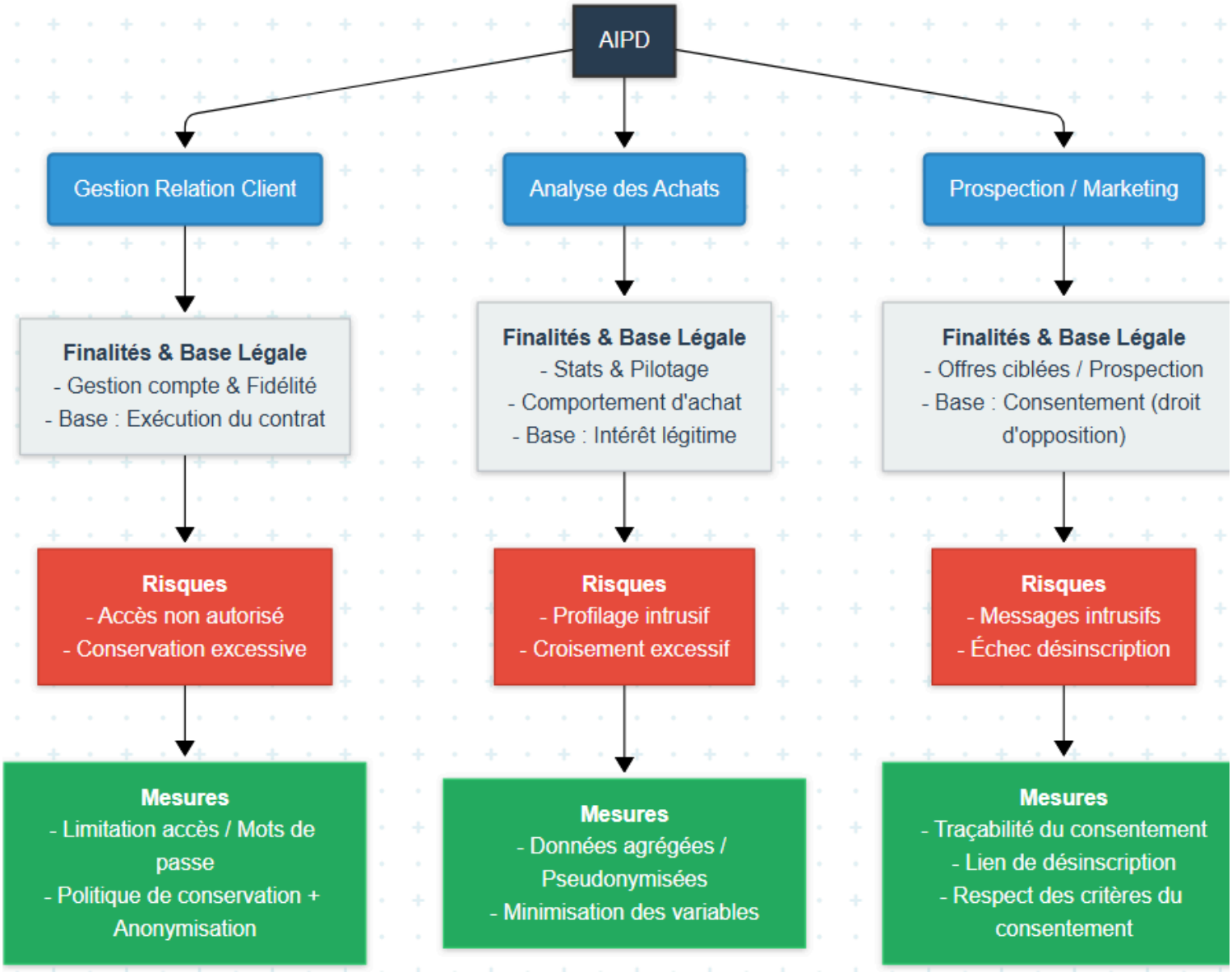
5) 3. RISQUES POUR LES PERSONNES CONCERNÉES

L'analyse des risques a mis en lumière des vulnérabilités potentielles liées à la nature des fichiers manipulés. Le risque principal réside dans le profilage intrusif résultant du croisement non contrôlé entre l'identité des 200 clients et leurs 1000 achats, ce qui pourrait conduire à une ingérence excessive dans leur vie privée ou à un ciblage marketing agressif. Il existe également un risque de sécurité lié à l'accès non autorisé aux fichiers, pouvant entraîner une fuite de données (vols d'emails, usurpation d'identité). Pour pallier ces menaces, des mesures techniques et organisationnelles robustes sont nécessaires. Sur le plan technique, nous préconisons l'anonymisation ou la pseudonymisation des bases de données avant toute utilisation statistique, ainsi qu'une gestion stricte des droits d'accès aux fichiers bruts (authentification forte). Sur le plan organisationnel, la sensibilisation du personnel et la mise en place de politiques de purge automatique garantissent que le principe de minimisation est respecté au quotidien.

5) 4. MESURES DE PROTECTION TECHNIQUES ET ORGANISATIONNELLES

Afin de réduire les risques, plusieurs mesures de protection techniques et organisationnelles peuvent être proposées à SuperPlus. Pour la protection technique, SuperPlus peut par exemple mettre en place une gestion des droits d'accès aux fichiers clients et achats, en limitant les accès aux seules personnes qui en ont besoin dans le cadre de leurs fonctions, dont des mécanismes d'authentification renforcée pour les utilisateurs. Les données de contact et l'historique d'achats peuvent être anonymisées lorsque des analyses statistiques sont réalisées, de manière à limiter la réidentification avec les clients.
Pour ce qui est de mesure organisationnelles, SuperPlus doit s'assurer que les clients sont clairement informés des finalités de traitement, et de la base légale applicable et de la durée des conservations de leurs données, au moment de la collecte et rendre les données facilement accessibles. Les procédures d'exercice des droits doivent être simples par exemple: lien de désinscription dans les emails de prospection, un formulaire de contact pour les demandes d'accès ou de suppression des données. Par ailleurs, il est important pour SuperPlus de donner les durées de conservation (qui doivent être en accord avec ceux de la CNIL), et de bien anonymiser les données au-delà des durées.
Pour les traitements de prospection commerciale et de profilage marketing, des mesures renforcées doivent être mises en oeuvres afin que les clients aient la possibilité de s'y opposer et ce facilement. SuperPlus peut également mettre en place des dispositifs de sensibilisation aux exigences du RGPD, afin de s'assurer que les principes de minimisation des données, de limitation des finalités et de sécurité sont intégrés dans les pratiques quotidiennes. L'ensemble de ces mesures aident à abaisser le niveau de risque qu'on a pu identifier dans l'AIPD et à renforcer la conformité de l'entreprise.

6. REPRÉSENTATION DE L'AIPD SOUS LA FORME D'UN SCHÉMA VISUEL



7. APPRÉCIATION DU NIVEAU DE RISQUE ET SOLUTIONS.

À l'issue de cette analyse d'impact, nous évaluons le niveau de risque initial comme "significatif" en raison de la granularité des données comportementales et de la sensibilité des informations de contact traitées. Toutefois, ce risque n'est pas une fatalité. En déployant l'ensemble des mesures de protection identifiées (limitation des durées de conservation, sécurisation des accès, respect strict du consentement pour la prospection), SuperPlus est en mesure de ramener le risque résiduel à un niveau faible et acceptable. La solution recommandée consiste à formaliser ces processus dans un registre des traitements tenu à jour et à effectuer une revue régulière de l'AIPD, notamment lors du lancement de nouvelles campagnes marketing, afin d'assurer une conformité continue et dynamique.

8. CONCLUSION

Dans le cadre de notre analyse pour SuperPlus, nous avons démontré que les objectifs de compréhension du comportement client et d'évaluation de l'efficacité marketing peuvent être atteints sans compromettre la conformité RGPD. L'AIPD réalisée met en évidence que le risque principal réside dans la combinaison de données personnelles identifiables avec des informations comportementales détaillées, ce qui expose l'entreprise à un profilage intrusif, à un défaut de base légale pour certaines sollicitations marketing et à un manque de transparence perçu par les clients.

L'étude nous conduit à conclure que plusieurs traitements nécessitent un encadrement renforcé, notamment ceux liés à la prospection ciblée. Le test de mise en balance montre que le recours systématique à l'intérêt légitime n'est pas suffisant : certaines actions marketing exigent un consentement clair et traçable. De plus, la durée de conservation actuelle des informations apparaît disproportionnée face aux recommandations de la CNIL, ce qui constitue un risque de non-conformité. Enfin, l'évaluation des accès internes souligne la nécessité d'un contrôle plus strict pour limiter l'exposition des données sensibles.

Les solutions proposées permettent de réduire le niveau de risque à un seuil faible : anonymisation des données avant analyse statistique, révision des durées de conservation, mise en place d'un registre des traitements, suivi rigoureux du consentement, renforcement des mécanismes internes de sécurité et simplification de l'exercice des droits.

Ces mesures assurent un respect des principes fondamentaux du RGPD tout en préservant la capacité de l'entreprise à exploiter ses données pour optimiser son offre et améliorer la pertinence de ses campagnes marketing. Ainsi, nos conclusions montrent que la conformité ne constitue pas un frein à la performance commerciale : au contraire, elle crée les conditions pour installer un climat de confiance, garantir la légitimité des actions marketing et maintenir une utilisation durable et responsable des données.

Plus largement, ce projet nous a permis de prendre conscience du rôle central que joue aujourd'hui la conformité des données dans les activités numériques. Dans un environnement où les organisations cherchent à exploiter les informations à grande échelle pour orienter leur stratégie, le RGPD apparaît non plus comme une contrainte, mais comme un outil indispensable pour garantir éthique, transparence et sécurité.

Les compétences mobilisées au cours de cette SAÉ ont été multiples : analyse juridique, compréhension des exigences réglementaires, formalisation d'une AIPD complète, réflexion stratégique sur la gestion des risques, sécurisation des traitements, restitution synthétique et vulgarisation des résultats. Ce travail nous a appris à articuler analyse technique et responsabilité, à anticiper les impacts organisationnels, et à valoriser les données tout en protégeant les personnes.

Au terme de cette expérience, une conclusion s'impose : protéger les données, c'est protéger l'entreprise. La conformité RGPD devient un levier durable de performance, d'innovation et de confiance, indissociable de l'avenir des métiers de la data.

MERCI POUR VOTRE ATTENTION

SAE RÉALISÉ PAR :
THOMAS AYMARD, MANCEF HENICHE, YUSUF ASLAN & MALIK BESSABIS - BUT SD 2 VCOD FI